

CO5-AT1

ITA1407 - Ethical Hacking

NAME: RISHI VARTHINI S

REG NO: 192421304

Question 1:

A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt.

Answer:

Given:

Total systems = 150

Systems allowing anonymous enumeration = 45%

Systems susceptible to SMB lateral movement = 60%

Additional systems attempted per compromised system = 3

Success probability per attempt = 0.3

Step 1: Initial Stage Compromise

Number of systems allowing anonymous enumeration:

$$\begin{aligned}\text{Initial compromised systems} &= 150 \times 45\% \\ &= 150 \times 0.45 \\ &= 67.5\end{aligned}$$

Therefore, approximately 68 systems are compromised during the initial stage.

Step 2: Systems Susceptible to SMB-Based Lateral Movement

$$\begin{aligned}\text{SMB-susceptible systems} &= 67.5 \times 60\% \\ &= 67.5 \times 0.60 \\ &= 40.5\end{aligned}$$

Therefore, approximately 40.5 compromised systems are susceptible to SMB-based lateral movement.

Step 3: Second Stage Spread

Each susceptible system attempts to access 3 additional systems with a success probability of 0.3.

$$\begin{aligned}\text{Expected successful compromises per system} &= 3 \times 0.3 \\ &= 0.9\end{aligned}$$

$$\begin{aligned}\text{Total second-stage compromise} &= 40.5 \times 3 \times 0.3 \\ &= 36.45\end{aligned}$$

Therefore, approximately 36 additional systems are compromised during the second stage.

Step 4: Total Expected Compromise

$$\begin{aligned}\text{Total compromised systems} &= \text{Initial compromise} + \text{Second-stage compromise} \\ &= 67.5 + 36.45 \\ &= 103.95 \\ &\approx 104 \text{ systems}\end{aligned}$$

$$\begin{aligned}\text{Percentage of network compromised} &= (103.95 / 150) \times 100 \\ &= 69.3\%\end{aligned}$$

Analysis:

The expected attack compromises approximately 104 out of 150 systems, which represents 69.3% of the network. This is slightly below the 70% threshold for a large-scale compromise. However, the network is at very high risk because even a small increase in the exploitation success rate could push the compromise above 70%.

Among the vulnerabilities, NULL sessions should be prioritized for immediate mitigation. NULL sessions allow anonymous users to enumerate system information, users, and shared resources, helping attackers gain an initial foothold. Since the initial compromise affects 45% of the systems, eliminating anonymous enumeration can significantly reduce the starting point of the attack and consequently reduce later SMB-based lateral movement.

Conclusion:

Initial stage compromise = Approximately 68 systems
Second-stage compromise = Approximately 36 systems
Total expected compromise = Approximately 104 systems
Percentage compromised = 69.3%

The network is at very high risk of a large-scale compromise.

Priority for immediate mitigation: NULL Sessions

Question 2

An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Answer:

Given:

Total systems = 120

Systems exposing RPC services = 70

Vulnerable RPC systems = 40%

Probability of successful exploitation = 0.5

Probability of detection per exploitation attempt = 0.25

Step 1: Calculate the Number of Vulnerable Systems

$$\begin{aligned}\text{Vulnerable systems} &= 70 \times 40\% \\ &= 70 \times 0.40 \\ &= 28 \text{ systems}\end{aligned}$$

Therefore, 28 systems are vulnerable to known RPC exploits.

Step 2: Calculate the Expected Number of Successfully Compromised Systems

$$\begin{aligned}\text{Expected successful compromises} &= \text{Number of vulnerable systems} \times \text{Success probability} \\ &= 28 \times 0.5 \\ &= 14 \text{ systems}\end{aligned}$$

Therefore, the expected number of successfully compromised systems is 14.

Step 3: Calculate the Expected Number of Detection Alerts

Each exploitation attempt has a detection probability of 0.25.

$$\begin{aligned}\text{Expected detection alerts} &= \text{Number of exploitation attempts} \times \text{Detection probability} \\ &= 28 \times 0.25 \\ &= 7 \text{ alerts}\end{aligned}$$

Therefore, approximately 7 detection alerts are expected.

Analysis:

An attacker can expect to successfully compromise 14 systems. However, approximately 7 detection alerts may also be generated during the exploitation process. This means that the attack has a significant probability of being detected by the intrusion detection system.

An attacker whose objective is to remain stealthy may not proceed with large-scale direct exploitation of all vulnerable RPC systems. Multiple exploitation attempts can create multiple alerts, allowing security administrators to identify the attack and respond quickly.

A stealth-focused attacker may instead use alternative strategies such as limited targeted exploitation, credential theft, phishing, reconnaissance, or exploiting fewer high-value systems to reduce the probability of detection.

Conclusion:

Vulnerable RPC systems = 28

Expected successfully compromised systems = 14

Expected detection alerts = 7

Direct exploitation is risky for an attacker who wants to remain stealthy because it is likely to generate several detection alerts. Therefore, alternative and less detectable attack strategies would be preferable.

Question 3

A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Answer:**Given:**

Probability that Service 1 is vulnerable = 0.30

Probability that Service 2 is vulnerable = 0.20

Probability that Service 3 is vulnerable = 0.25

Probability that Service 4 is vulnerable = 0.15

Probability of privilege escalation through weak file permissions = 0.50

Step 1: Calculate the Probability That At Least One Service Is Vulnerable

First, calculate the probability that none of the services is vulnerable.

$$\begin{aligned} P(\text{None vulnerable}) &= (1 - 0.30)(1 - 0.20)(1 - 0.25)(1 - 0.15) \\ &= 0.70 \times 0.80 \times 0.75 \times 0.85 \\ &= 0.357 \end{aligned}$$

Therefore, the probability that at least one service is vulnerable is:

$$\begin{aligned} P(\text{At least one vulnerable}) &= 1 - P(\text{None vulnerable}) \\ &= 1 - 0.357 \\ &= 0.643 \end{aligned}$$

Therefore:

$$P(\text{At least one service is vulnerable}) = 64.3\%$$

Step 2: Calculate the Overall Probability of Full System Compromise

For a full system compromise, the attacker must first exploit at least one vulnerable service and then successfully perform privilege escalation through weak file permissions.

$$\begin{aligned} P(\text{Full system compromise}) &= P(\text{At least one vulnerable}) \times P(\text{Privilege escalation}) \\ &= 0.643 \times 0.50 \\ &= 0.3215 \end{aligned}$$

Therefore:

$$P(\text{Full system compromise}) = 32.15\%$$

Analysis:

There is a 64.3% probability that at least one internet-facing service is vulnerable. Once the attacker gains initial access, weak file permissions provide a 50% probability of successful privilege escalation.

Strengthening file permissions would significantly reduce the probability of a full system compromise because it reduces the privilege-escalation stage. However, strengthening file

permissions alone would not eliminate the overall security risk because the probability of initial access through vulnerable services remains 64.3%.

An attacker could still exploit vulnerable services, access application data, execute commands with limited privileges, or use other methods for privilege escalation.

Conclusion:

Probability that at least one service is vulnerable = 64.3%

Probability of full system compromise = 32.15%

Strengthening file permissions is important and would significantly reduce the risk of full system compromise. However, it alone is not sufficient. Vulnerable services must also be patched, unnecessary services should be disabled, and proper access control and monitoring should be implemented.

Question 4

An organization uses Network File System (NFS) to share resources across three internal subnets. Due to improper configuration, unauthorized access probabilities from these subnets are estimated as 0.4, 0.3, and 0.2, respectively. Once access to the NFS share is obtained, the probability of privilege escalation to root access is 0.7.

Answer:

Given:

Probability of unauthorized access from Subnet 1 = 0.40

Probability of unauthorized access from Subnet 2 = 0.30

Probability of unauthorized access from Subnet 3 = 0.20

Probability of privilege escalation to root access = 0.70

Step 1: Calculate the Probability That At Least One Subnet Gains Unauthorized Access

First, calculate the probability that none of the subnets gains unauthorized access.

$$P(\text{None gains access}) = (1 - 0.40)(1 - 0.30)(1 - 0.20)$$

$$= 0.60 \times 0.70 \times 0.80$$

$$= 0.336$$

Therefore, the probability that at least one subnet gains unauthorized access is:

$$P(\text{At least one gains access}) = 1 - 0.336$$

$$= 0.664$$

Therefore:

$$P(\text{At least one subnet gains unauthorized access}) = 66.4\%$$

Step 2: Calculate the Overall Probability of Complete System Compromise

A complete compromise requires unauthorized NFS access followed by successful privilege escalation to root access.

$$P(\text{Complete compromise}) = P(\text{Unauthorized access}) \times P(\text{Privilege escalation})$$

$$= 0.664 \times 0.70$$

$$= 0.4648$$

Therefore:

$$P(\text{Complete system compromise}) = 46.48\%$$

Step 3: Evaluate Restricting NFS Access to a Single Subnet

Restricting NFS access to only one trusted subnet reduces the number of possible attack sources.

For example, if access is restricted to the subnet with an unauthorized access probability of 0.20:

$$P(\text{Complete compromise}) = 0.20 \times 0.70$$

$$= 0.14$$

$$= 14\%$$

Thus, the compromise probability can be reduced from 46.48% to 14% in this example.

Analysis:

The original NFS configuration creates a 66.4% probability that at least one subnet gains unauthorized access. Once access is obtained, the 70% probability of privilege escalation results in a high complete compromise probability of 46.48%.

Restricting NFS access to a single trusted subnet is an effective mitigation strategy because it reduces the attack surface and limits the number of networks that can attempt unauthorized access.

However, restricting access alone should not be the only security measure. The organization should also use strict NFS export rules, allow only authorized hosts, apply least-privilege permissions, and use root squashing where appropriate.

Conclusion:

Probability of at least one subnet gaining unauthorized access = 66.4%

Probability of complete system compromise = 46.48%

Restricting NFS to one trusted subnet can significantly reduce the risk. Therefore, restricting NFS access to only required and trusted subnets is strongly recommended.

Question 5

An e-commerce platform maintains a database containing 50,000 user records, of which 30% are classified as sensitive. A successful SQL injection attack allows data extraction at a rate of 500 records per second. However, the application firewall detects and blocks the attack after 40 seconds.

Answer:

Given:

Total user records = 50,000

Percentage of sensitive records = 30%

Data extraction rate = 500 records per second

Time before attack is blocked = 40 seconds

Step 1: Calculate the Total Number of Records Extracted

Total records extracted = Extraction rate × Time

$$= 500 \times 40$$

$$= 20,000 \text{ records}$$

Therefore, 20,000 records can be extracted before the attack is blocked.

Step 2: Calculate the Percentage of Total Data Compromised

Percentage of data compromised = (Extracted records / Total records) × 100

$$= (20,000 / 50,000) \times 100$$

$$= 40\%$$

Therefore, 40% of the total database is compromised.

Step 3: Calculate the Number of Sensitive Records in the Database

Total sensitive records = $50,000 \times 30\%$

$$= 50,000 \times 0.30$$

$$= 15,000 \text{ records}$$

Step 4: Estimate the Number of Sensitive Records Exposed

Assuming sensitive records are distributed proportionally in the extracted data:

Sensitive records exposed = $20,000 \times 30\%$

$$= 20,000 \times 0.30$$

$$= 6,000 \text{ records}$$

Therefore, approximately 6,000 sensitive records are exposed.

Analysis:

The breach is highly severe because 20,000 out of 50,000 records are extracted before the application firewall blocks the attack. This represents 40% of the entire database. Approximately 6,000 sensitive records may also be exposed.

Although the application firewall successfully detects and blocks the attack, detection after 40 seconds is not sufficient to protect critical data because a large amount of information has already been extracted.

The organization should use stronger preventive and detection mechanisms, including parameterized queries or prepared statements, input validation, secure coding practices, rate limiting, faster WAF blocking, database access controls, and continuous monitoring.

Conclusion:

Total records extracted = 20,000

Percentage of total data compromised = 40%

Total sensitive records in database = 15,000

Estimated sensitive records exposed = 6,000

Breach severity = HIGH

The existing detection mechanism is not sufficient because it allows 20,000 records, including approximately 6,000 sensitive records, to be extracted before the attack is blocked.